PayPilot · 带策略护栏的 AI 购物支付智能体

2026 华为开发者大赛 · 智能体创新赛（中部赛区） | 参赛主体：OPC（一人公司 / 超级个体） | 场景方向：企业场景 · 办公协同与流程创新

172	0	5	7
断言全部通过（0 失败）	第三方依赖	道策略护栏闸口	步可审计决策链

一、场景背景

智能体正从「能对话」走向「能做事」。一旦 AI 被授予真实支付能力，企业面临的不再是模型能力问题，而是**资金安全与责任归因**问题。

二、真实痛点（三条）

- **缺乏事前管控**：多数智能体的金额管控在付款之后才生效，钱已出手。
- **提示词护栏可被绕过**：把「不许乱花钱」写进 prompt，模型可被说服放行——护栏缺少架构级保证。
- **决策无法归因**：智能体为什么买这件、为什么放行，事后查不到证据链。

目标用户：需要给 AI 智能体授予受限支付/采购权限的企业与超级个体（OPC）。

三、PayPilot 的应对

- 在**触碰资金之前**执行策略引擎（pre-flight），不过闸则不调用支付 API。
- 策略覆写路径**对大模型不可见**——不是「提示词里写一句」，而是模型根本拿不到绕过开关。
- 每一步决策产出**带字段引用的审计链**，可完整回放。

四、实测（本机可复现）

命令	结果
python eval.py	`172 passed / 0 failed`
python -m paypilot demo	`4 场景端到端通过`
演示视频	`21.53s / 1280×720`

功能架构与决策链

纯 Python 标准库实现 · OpenAI 兼容 LLM 或确定性离线引擎双通道 · 模型不可用时优雅降级

决策链（7 步，全链路可审计）

PERCEIVE → SEARCH → SELECT → **POLICY** → EXPLAIN → EXECUTE → CAPTURE

POLICY 是关键闸口：位于 EXECUTE 之前，未通过则不进入支付调用。策略判定独立于模型输出，模型只能看到「通过/拒绝」的结果，看不到覆写参数。

策略引擎：五道闸

- 单笔金额上限
- 日累计金额上限
- 类目白名单
- 商户黑名单
- 大额人工审批阈值

模块构成（2,609 行）

agent.py · catalog.py · **policy.py** · reasoning.py · paypal.py · mock_paypal.py · receipts.py · renewals.py · grid.py · web.py · cli.py · api.py · context.py

真实运行输出（demo 场景 1）

```
request : Birthday gift for my mom, under $50
status : COMPLETED
product : Deluxe Garden Tool Set (G001)
merchant : GreenThumb Co
price : $34.99  rating: 4.6/5
policy : ALLOW (ALL_CHECKS_PASSED)
paypal order : MOCK-ORDER-25413FA805
capture id : MOCK-CAPTURE-7361D66DDA

decision trail:
  [PERCEIVE] understood the request via offline engine
  [SEARCH] ranked 3 candidate(s) from the catalog
  [SELECT] selected Deluxe Garden Tool Set at $34.99
  [POLICY] ALLOW - order is within policy
  [EXPLAIN] ...matches your request on 4 signal(s)...
  [EXECUTE] created PayPal order (CREATED)
  [CAPTURE] payment COMPLETED
```

全部输出为离线 mock 模式实跑结果，无需任何 API Key，评委可直接复现。

核心亮点：护栏是架构隔离，不是提示词

差异化创新点 · 对应评分维度「专业贴合与创新 25 分」

亮点 1 · 覆写路径对模型不可见

常见做法是把消费规则写进 system prompt，模型可通过多轮对话、角色扮演等方式被说服放行。PayPilot 把策略引擎实现为**独立模块**，其覆写参数不进入模型的上下文与工具列表——模型在结构上无法触达绕过开关。护栏因此是**可证明的**，而非需要被信任的。

亮点 2 · 事前（pre-flight）而非事后

策略检查发生在调用支付 API **之前**。不过闸不生成订单、不占用资金，从流程上消除了「先斩后奏」。

亮点 3 · 证据可引用

每个候选商品与每条策略判定都引用其所依据的字段（价格、类目、商户、命中信号数），解释不是模型自由发挥，而是**绑定证据**生成。

亮点 4 · 零依赖 + 完全离线可复现

- 纯 Python 标准库，**pip install 无内容**，评委 `git clone` 即跑。
- 双引擎：OpenAI 兼容 LLM（可接小米 MiMo 等）**或**确定性离线引擎；模型不可用时自动降级，评测不依赖任何 Key。
- 172 条断言覆盖完整 agent 循环与进程内 PayPal mock。

亮点 5 · 工程交付完备

- OpenAPI 3.0 规范 + Postman 集合
- Web 界面（web.py）与 HTTP 服务（server.py）
- render.yaml 云端部署配置
- MIT 许可，GitHub / Gitee 双公开

落地价值

可直接作为企业「AI 采购助手」「订阅续费管控」的资金安全底座；renewals.py（565 行）已实现订阅续费管理场景，具备真实业务延展性。

华为云码道（CodeArts）应用说明

对应评分维度「码道深度使用 25 分」—— 覆盖环境搭建 / 代码生成 / 调试排错 / 文档生成 全流程

码道在开发全流程的覆盖

环节	码道承担的工作	产物
环境搭建	生成一键安装脚本与环境自检工具	scripts/setup.sh · doctor.py
代码生成	新增「商户黑名单模糊匹配」护栏；为检索增加命中明细字段	policy.py · catalog.py · 新断言
调试排错	定位日累计边界判定不稳定缺陷并修复（定点分比较）	renewals.py 修复 + 回归断言
文档生成	生成 API 文档、架构说明、部署运行说明	readme/ 全套 Markdown

Prompt 设计要点

- 每条提示词**明确指定目标文件与现有符号**（如 `check(policy, product, daily_spent)`），避免码道臆造接口。
- 显式声明约束：**纯标准库、零依赖、不得引入 LLM 可覆写参数**，保证改动不破坏核心安全性质。
- 要求码道**同时输出断言代码**，使每次生成都受到 172 条回归测试约束。

使用证明材料（codearts_proof/）

- 核心功能开发的 **AI 交互对话与 Prompt 截图**（A/B/C/D 四组共 6 条）
- 代码生成、重构、排错的**过程记录**
- 码道 IDE 插件**操作日志与记录**
- 每条提示词对应的**本地执行终端输出**（含 eval.py 结果）

交付规范（5 文件夹）

```
PayPilot_<队名>_v1.0_<联系方式>.zip
├─ ppt/              作品介绍 PDF
├─ project/          可运行 Demo
├─ video/            演示视频 21.53s
├─ codearts_proof/   码道使用证明
└─ readme/           说明文档
```

真实性声明：全部码道使用痕迹为真实开发过程记录，未做任何合成或伪造。